PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Analyse des groupes APT31, Nobelium et Houken

03-1180 CERT-FR - Les modes opératoires APT31, Nobelium et Houken — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. APT31 utilise un réseau d'anonymisation composé de routeurs SOHO gérés par la porte dérobée Pakdoor.
2. Nobelium, lié au SVR, cible prioritairement les entités diplomatiques en utilisant des comptes compromis.
3. Houken exploite des vulnérabilités jour-zéro sur des équipements de bordure et agit probablement comme un courtier en accès initiaux.

APT31 : Synthèse de la menace

Notion	À retenir
La campagne	Campagne contre des entités françaises signalée en **janvier 2021**, mode opératoire réputé **chinois** ; approche **opportuniste** sans critère sectoriel.
Les vecteurs d'intrusion	Force brute (**Autodiscover** d'Exchange, services exposés), comptes locaux valides (**VPN**, **RDP**, **Office 365**) et vulnérabilités (**ProxyLogon**, **Fortinet**, injections SQL).
L'infrastructure d'anonymisation	~**1 000** routeurs SOHO compromis en réseau maillé (**64 %** de marque **Pakedge**, plus **Sophos Cyberoam** et **Cisco**), gérés par la porte dérobée `Pakdoor` pour le C2 de **Cobalt Strike**.

Synthèse Nobelium

Notion	À retenir
Mode opératoire SVR	**Nobelium** (**Midnight Blizzard**), actif depuis **octobre 2020**, lié au **SVR**. L'ANSSI distingue **3 modes opératoires** SVR : **APT29** (The Dukes, depuis 2008), **Nobelium**, **Dark Halo** (SolarWinds 2020).
Campagnes France	Février-mai **2021** : comptes compromis (**ministère de la Culture**, **ANCT**), pièce jointe `Strategic Review`. **2022** : dizaines d'adresses du **ministère des Affaires étrangères** (échec). **Mai 2023** : ambassades à **Kyiv** et en **Roumanie**, sans succès grâce aux agents.
Recommandations	Ne pas exécuter de **pièces jointes suspectes** et durcir la sécurité de l'**Active Directory** (cible privilégiée).

Synthèse de l'activité Houken

Notion	À retenir
Campagne Ivanti (septembre 2024)	Exploitation de **3 vulnérabilités** jour-0 sur **Ivanti Cloud Service Appliance** ; impactent des secteurs français (gouvernement, télécoms, médias, finance, transports) avec **3 cas de latéralisation**.
Profil ambivalent	Utilise **jour-0**, **rootkit** et outils libres sinophones. Probablement un **courtier en accès initiaux** revendant à un acteur étatique ; même opérateur que **UNC5174** (courtier possible du **ministère chinois de la Sécurité d'État**).

Pièges et confusions

- ⚠ Confondre l'approche opportuniste d'APT31 avec le ciblage diplomatique de Nobelium.
- ⚠ Croire que le réseau d'anonymisation d'APT31 repose sur des serveurs classiques plutôt que sur des routeurs SOHO.
- ⚠ Oublier que l'Active Directory est une cible privilégiée pour Nobelium.
- ⚠ Confondre l'utilisation de jour-zéro par Houken avec une approche sans vulnérabilités.
- ⚠ Croire que Nobelium et APT29 sont le même mode opératoire : l'ANSSI distingue trois modes opératoires liés au SVR.

Sigles et définitions

Intrusion set	Ensemble des outils, tactiques, techniques et procédures mis en œuvre par un ou plusieurs acteurs.
Réseau d'anonymisation	Ensemble de machines compromises, souvent des routeurs, par lesquelles transitent les communications d'un attaquant pour masquer son origine.
Routeurs SOHO	Routeurs de petites entreprises et de particuliers.
Access broker	Obtient des accès à des réseaux pour les revendre à d'autres acteurs.
Webshell	Script déposé sur un serveur web qui permet de le commander à distance.
Rootkit	Code malveillant qui se dissimule au cœur du système, ici sous forme de module du noyau.

Auto-test

1. À quel service de renseignement est lié Nobelium ?
2. Quelle marque de routeur est présente dans 64 % du réseau d'anonymisation d'APT31 ?
3. Quels équipements sont des points critiques à protéger selon les alertes ?
4. Quelle vulnérabilité a été exploitée par Houken sur Ivanti ?
5. Quel est le nom de la porte dérobée utilisée par APT31 pour le C2 de Cobalt Strike ?

Réponses : **1.** SVR · **2.** Pakedge · **3.** Équipements de bordure et Active Directory · **4.** 3 vulnérabilités jour-0 · **5.** Pakdoor

---

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.